Portability audit, 2026-10-29 (English summary)

Canonical Russian source with the full detail: ../../audit/portability-audit-2026-10-29.md. This page summarises the findings and what changed; it is not a word-for-word translation of every diff.

Verdict

The project was a working application with production secrets and unsafe defaults in the code. After the audit it is reproducible on a clean machine, has no secrets in the repository or its history, and its claims are backed by tests.

What was found and fixed

Area	Finding	Fix
Secrets	Gmail app password as a default value	configuration from the environment only, `app/mailer.py`
Secrets	admin code `ADMIN123` in code	`ADMIN_CODE` from the environment, 503 when unset, constant-time compare
History	Telegram bot token and a base64 key in old commits	`git filter-repo --replace-text`, force-push, `gitleaks` shows 0
CORS	`*` together with credentials	`CORS_ORIGINS`, same-origin by default
Tests	network calls through keep-alive during import	opt-in flag, disabled under `ENV=test`
Tests	one database shared between tests	temporary `DB_PATH` per test (`tests/conftest.py`)
Reproducibility	unpinned dependencies	`requirements.txt` / `requirements-dev.txt` with exact versions
Control	no single entry point	`Makefile` (`doctor|install|test|lint|check`) plus `forge.sh/forge.bat`
Licence	none	MIT
Structure	one 750-line file	`app/` package: config, db, security, mailer, models, routers

What is intentionally left

- Unsalted SHA-256 password hashing (compatibility with existing accounts) — documented as a limitation in `modules/auth.md`.
- No rate limiting, no password reset.
- SQLite and a single process: the deployment model is documented, not changed.

How to re-check

```
make doctor && make check        # tools, lint, tests, documentation
gitleaks git                     # history is clean
make docs-pdf                    # both languages build
```